

# CodBi – KI-Komponenten ReadMe & Compliance-Guide

**Zielgruppe:** Administratoren, Datenschutzbeauftragte, Sicherheitsverantwortliche und Entwickler, die CodBi in XIMA formcycle betreiben oder evaluieren.

VERSION 1.0.1

LOKALER KI-STACK

DSGVO-KONFORM

EU AI ACT

## 1. Überblick

**CodBi** ist ein XIMA-formcycle-Plugin (Kotlin + TypeScript), das einen vollständig **lokal betriebenen KI-Stack** direkt auf dem formcycle-Applikationsserver bereitstellt. Es gibt keine obligatorischen Cloud-Abhängigkeiten — alle KI-Inferenz-Prozesse kommunizieren ausschließlich über `127.0.0.1`.

Das Plugin bündelt vier KI-Funktionsbereiche:

| Bereich                       | Technologie                  | Zweck                                                             |
|-------------------------------|------------------------------|-------------------------------------------------------------------|
| <b>Textgenerierung / Chat</b> | llama.cpp (LLaMA-Server)     | Formular-Assistent, Frage-Antwort, Dokumentenanalyse              |
| <b>Spracherkennung</b>        | whisper.cpp (Whisper-Server) | Audioeingabe / Diktat in Formularen                               |
| <b>Texterkennung (OCR)</b>    | Tesseract JNI (tess4j)       | Scan- und Bilddaten aus Formular-Uploads                          |
| <b>KI-Proxy-API</b>           | AiProxy (Reverse-Proxy)      | Authentifizierter Zugang zu allen KI-Diensten für externe Clients |

Alle vier Komponenten sind unabhängig aktivierbar (Property `Active_AI`).

## 2. KI-Architektur

```

formcycle-Server (JVM / Apache Tomcat)
└─ CodBi-Plugin (Kotlin)
    ├── AI.kt                – Semaphore (FIFO), Queue, Bild-Cache
    ├── AiProxy.kt          – Authentifizierter HTTP-Reverse-Proxy
    ├── BraveSearch.kt      – Optionale Websuche (Opt-In)
    ├── MailBridge.kt       – KI-gesteuerter E-Mail-Versand (Opt-In)
    ├── UrlFetcher.kt       – SSRF-gesicherter HTML-Fetcher
    └─ ai/
        ├── LLAMA.kt        – Abstrakte LLaMA-Basisklasse
        ├── llama/Standard.kt – Qwen3-VL + Thinking + Specialists
        ├── Whisper.kt      – whisper.cpp Wrapper
        ├── Tesseract.kt    – OCR via tess4j JNI
        └─ commons/        – Gemeinsame Infrastruktur
  
```

## Externe KI-Prozesse

Laufen als Kind-Prozesse der JVM:

| Prozess                                  | Standardport                 | Funktion                                   |
|------------------------------------------|------------------------------|--------------------------------------------|
| <code>llama-server</code> (Haupt)        | <code>localhost:8392</code>  | Texte, Bilder, Chat                        |
| <code>llama-server</code> (Thinking)     | <code>localhost:8492</code>  | Erweitertes Reasoning (+100 zum Hauptport) |
| <code>llama-server</code> (Specialist N) | <code>localhost:8592+</code> | Optionale Fachmodelle                      |
| <code>whisper-server</code>              | <code>localhost:8393</code>  | Spracherkennung                            |
| Tesseract JNI                            | <i>kein HTTP-Port</i>        | In-Process OCR                             |

### CRASHISOLATION

LLaMA- und Whisper-Server laufen als separate OS-Prozesse. Ein Speicherüberlauf (OOM) im Modell beendet nur den Kind-Prozess — die formcycle-JVM und das Plugin bleiben stabil. CodBi erkennt den Ausfall und startet den Prozess automatisch neu.

## 3. Komponenten im Detail

### 3.1 LLaMA (Sprachmodell)

**Technologie:** llama.cpp — open-source C++-Inferenz-Engine für GGUF-Modelle

**Standardmodell:** Qwen3-VL 2B Instruct (Q4\_K\_M) — multimodales Modell (Text + Bild)

Modi

| Modus                   | Beschreibung                                                                |
|-------------------------|-----------------------------------------------------------------------------|
| <b>Standard-Chat</b>    | Konversation, Dokumentenanalyse, Formularunterstützung                      |
| <b>Thinking-Modus</b>   | Erweitertes Reasoning auf separatem Server (Timeout: 600 s)                 |
| <b>Specialist-Modus</b> | Aufruf eines benannten Fachmodells via <code>specialist=&lt;Name&gt;</code> |
| <b>Externer Modus</b>   | Weiterleitung an eine OpenAI-kompatible API (z. B. GPT-4o, Groq, Gemini)    |
| <b>Vision</b>           | Bild-/PDF-Analyse über eingebettete Base64-Bilder                           |

**Hardware-Beschleunigung (automatische Erkennung, absteigend)**

1. NVIDIA CUDA 12
2. Vulkan (AMD, Intel, alle Vulkan-fähigen GPUs)
3. CPU (universelle Fallback-Option)

**Kontextfenster:** 32 768 Tokens (konfigurierbar)

### 3.2 Whisper (Spracherkennung)

**Technologie:** whisper.cpp — C++-Port des OpenAI Whisper-Modells

**Standardmodell:** `ggml-small.bin` (~466 MB)

Features

- Kompatibel mit der OpenAI `/v1/audio/transcriptions`-API
- Automatische Sprachdetektion (opt-in via `AI_Whisper_AutoDetectLanguage`)
- GPU-Unterstützung (abschaltbar mit `AI_Whisper_NoGpu`)
- Optionale Nutzung einer externen STT-API

#### HINWEIS — BROWSER WEB SPEECH API

Die formcycle-Formulareingabe über `Media.Input.Speech` nutzt ggf. die

#### BROWSER-EIGENE WEB SPEECH API

(Google/Microsoft Cloud). Dies ist

#### UNABHÄNGIG

von CodBi Whisper und erfordert eine separate DSGVO-Einwilligung der Nutzenden.

### 3.3 Tesseract (OCR)

**Technologie:** tess4j 5.16.0 — Java-Binding für Tesseract OCR

**Besonderheit:** Tesseract läuft vollständig **in-process** (kein separater OS-Prozess, kein HTTP-Port).

Die nativen JNI-Bibliotheken werden plattformspezifisch geladen.

| Modus                | Beschreibung                                 |
|----------------------|----------------------------------------------|
| <code>print</code>   | Gedruckten Text aus Bildern/PDFs extrahieren |
| <code>extract</code> | Strukturierte Felderkennung per Regex        |
| <code>verify</code>  | Prüfung auf erkannte Zeichenfolgen           |

**Sprachen:** Konfigurierbar via `AI_Tesseract_Languages` (Standard: `deu`); Multiple Sprachen mit `+` verbinden (z. B. `deu+eng`).

**PDF-Verarbeitung:** PDFs werden via Apache PDFBox in Bilder gerastert, bevor Tesseract OCR angewendet wird.

### 3.4 AI-Proxy

Der **AiProxy** ist ein authentifizierter HTTP-Reverse-Proxy, der externen Clients einen gesicherten Zugang zu den lokalen KI-Diensten ermöglicht.

Base-URL

```
POST <formcycle-base>/plugin?name=CodBi_AI_Proxy&endpoint=<path>
```

## Endpunkte

| Endpunkt                              | Engine    | Beschreibung                                      |
|---------------------------------------|-----------|---------------------------------------------------|
| <code>/v1/chat/completions</code>     | LLaMA     | OpenAI-kompatibles Chat (inkl. Vision, Streaming) |
| <code>/completion</code>              | LLaMA     | Raw Completion (llama.cpp Low-Level-API)          |
| <code>/v1/audio/transcriptions</code> | Whisper   | Speech-to-Text (OpenAI-kompatibel)                |
| <code>/v1/ocr</code>                  | Tesseract | Texterkennung aus Bildern                         |

## Authentifizierung (zweistufig)

1. **IP-Whitelist** ( `AI_Proxy_AllowedIPs` ): CIDR-Bereiche und Einzel-IPs — leere Liste blockiert alle Anfragen
2. **HTTP Basic Auth** ( `AI_Proxy_Users` ): Format `benutzer:passwort,benutzer2:passwort2`

## Sonderfunktionen

| HTTP-Header                   | Beschreibung                                             |
|-------------------------------|----------------------------------------------------------|
| <code>X-Thinking: true</code> | Aktiviert den Thinking-Modus (Timeout: 600 s, Port +100) |

**Audit-Logging:** Jede Proxy-Anfrage wird in der Tabelle `codbi_ai_proxy` erfasst (siehe Abschnitt 7).

## 3.5 Brave Search (Websuche)

**Aktivierung:** Opt-In durch Setzen von `AI_BraveSearch_ApiKey`

Das Sprachmodell kann eigenständig Websuchen auslösen, indem es das Muster

`CALL:search(<Suchanfrage>)` in seiner Antwort produziert. Der `WebSearchHandler` fängt dieses Muster ab, ruft die Brave Search API auf und integriert die Ergebnisse in den Kontext.

| Property                                  | Standard           | Beschreibung                           |
|-------------------------------------------|--------------------|----------------------------------------|
| <code>AI_BraveSearch_ApiKey</code>        | <i>leer</i>        | API-Schlüssel — aktiviert die Websuche |
| <code>AI_BraveSearch_MaxResults</code>    | <code>5</code>     | Ergebnisse pro Suche (1–20)            |
| <code>AI_BraveSearch_FilterResults</code> | <code>false</code> | Sichere Suche / Ergebnisfilterung      |

#### DATENSCHUTZ

Bei aktivierter Websuche werden Suchanfragen an die Brave Search API übermittelt. Kein Nutzernamen und keine IP-Adresse werden weitergegeben. Eine Auftragsverarbeitungsvereinbarung (AVV) mit Brave ist zu prüfen.

### 3.6 MailBridge (KI-E-Mail)

**Aktivierung:** Opt-In durch `AI_Mail_Enabled = true`

Ermöglicht dem Sprachmodell, E-Mails im Namen des Systems zu versenden. Enthält mehrere Sicherheitsstufen:

- **Empfänger-Whitelist** per Regex ( `AI_Mail_AllowedRecipients` )
- **Globales Stundenlimit** ( `AI_Mail_MaxPerHour` , Standard: `10` )
- **Sitzungslimit** ( `AI_Mail_MaxPerSession` , Standard: `3` )
- **Pflicht-Disclaimer** im E-Mail-Footer (Standard: `AI-Generated` , konfigurierbar)

#### RECHTLICHE HINWEISE

KI-generierte E-Mails können Impressumspflichten und Kennzeichnungspflichten nach dem EU AI Act Art. 50 auslösen. Der Standard-Disclaimer ist zu prüfen und ggf. anzupassen.

### 3.7 Geolokalisierung

Das Sprachmodell kann den Standort des Servers für geografisch relevante Anfragen nutzen. Es werden zwei externe Dienste angesprochen (beide optional konfigurierbar):

| Dienst                      | Property                         | Zweck                                         |
|-----------------------------|----------------------------------|-----------------------------------------------|
| ipwho.is                    | AI_LLAMA_STD_IpGeolocationDomain | IP-basierte<br>Grobstandortbestimmung         |
| nominatim.openstreetmap.org | AI_LLAMA_STD_NominatimDomain     | Reverse-Geocoding<br>(Koordinaten → Ortsname) |

Ein Fallback-Standort kann ohne externe Dienste konfiguriert werden  
( AI\_LLAMA\_STD\_FallbackLocation ).

## 4. Modelle und Download-Quellen

Alle Modelle werden beim **ersten Start** automatisch heruntergeladen. Der Download unterstützt **Resume** (Fortsetzung unterbrochener Downloads). Für Air-Gapped-Umgebungen können eigene URLs oder lokale Spiegel konfiguriert werden.

| Komponente               | Standardmodell                     | Quelle                                 | Größe          |
|--------------------------|------------------------------------|----------------------------------------|----------------|
| LLaMA (Haupt)            | Qwen3VL-2B-Instruct-Q4_K_M.gguf    | huggingface.co/Qwen                    | ~1,1 GB        |
| LLaMA (Vision-Projektor) | mmpoj-Qwen3VL-2B-Instruct-F16.gguf | huggingface.co/Qwen                    | ~819 MB        |
| LLaMA-Server-Binary      | Release b8175 (Win/Linux/macOS)    | github.com/ggml-org/llama.cpp          | variiert       |
| Whisper                  | ggml-small.bin                     | huggingface.co/ggerganov               | ~466 MB        |
| Tesseract traineddata    | z. B. deu.traineddata              | github.com/tesseract-ocr/tessdata_best | ~30 MB/Sprache |

**Unterstützte GGUF-Modelle (Auswahl):** Qwen3, Mistral, LLaMA 3, Phi-3, Gemma — jedes im GGUF-Format verwendbare Modell ist via AI\_LLAMA\_STD\_ModelUrl einbindbar.

## 5. Konfigurationsreferenz

Die Konfiguration erfolgt ausschließlich über XIMA-formcycle-Plugin-Properties.

### 5.1 Aktivierung

| Property               | Beschreibung                                                                                                                                            |
|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>Active_AI</code> | Leerzeichen-getrennte Liste der aktiven Komponenten: <code>llama_engine</code> , <code>llama_std</code> , <code>whisper</code> , <code>tesseract</code> |

### 5.2 LLaMA Engine

| Property                                   | Standard               | Beschreibung                                                                     |
|--------------------------------------------|------------------------|----------------------------------------------------------------------------------|
| <code>AI_LLAMA_ENGINE_Port</code>          | <code>8392</code>      | Lokaler Port des LLaMA-Servers                                                   |
| <code>AI_LLAMA_ENGINE_Threads</code>       | Physische Kerne        | CPU-Threads für Inferenz                                                         |
| <code>AI_LLAMA_ENGINE_CtxSize</code>       | <code>32768</code>     | Kontextfenstergröße in Tokens                                                    |
| <code>AI_LLAMA_ENGINE_GpuLayers</code>     | <code>-1</code> (auto) | GPU-Offload: <code>-1</code> =auto, <code>0</code> =CPU, <code>N</code> =N Layer |
| <code>AI_LLAMA_ENGINE_Release</code>       | <code>b8175</code>     | llama.cpp Release-Tag für Download                                               |
| <code>AI_LLAMA_ENGINE_MaxConcurrent</code> | <code>2</code>         | Maximale parallele Inferenzen (Semaphore)                                        |

### 5.3 LLaMA Standard-Modell

| Property                                 | Standard                         | Beschreibung                         |
|------------------------------------------|----------------------------------|--------------------------------------|
| <code>AI_LLAMA_STD_ModelUrl</code>       | Qwen3-VL-2B Q4_K_M (HuggingFace) | URL des GGUF-Hauptmodells            |
| <code>AI_LLAMA_STD_MmprojUrl</code>      | Qwen3-VL-2B mmproj F16           | URL des Vision-Projektors (optional) |
| <code>AI_LLAMA_STD_MaxPixels</code>      | <code>3211264</code>             | Pixelbudget für Bildskalierung       |
| <code>AI_LLAMA_STD_MaxUploadBytes</code> | <code>52428800</code> (50 MB)    | Maximale Upload-Größe                |

| Property                                    | Standard              | Beschreibung                                                                    |
|---------------------------------------------|-----------------------|---------------------------------------------------------------------------------|
| <code>AI_LLAMA_STD_MaxTokens</code>         | <code>2048</code>     | Maximale generierte Tokens pro Anfrage                                          |
| <code>AI_LLAMA_STD_MaxRAMPercent</code>     | <code>101.0</code>    | RAM-Auslastungsschwelle (Anfragen ablehnen)                                     |
| <code>AI_LLAMA_STD_MaxComputePercent</code> | <code>101.0</code>    | CPU/GPU-Auslastungsschwelle                                                     |
| <code>AI_LLAMA_STD_Language</code>          | <code>auto</code>     | Erzwungene Antwortsprache (ISO 639-1, z. B. <code>de</code> )                   |
| <code>AI_LLAMA_STD_PromptIdentity</code>    | <code>built-in</code> | Eigener Identitätsprompt ( <code>{date}</code> , <code>{time}</code> verfügbar) |
| <code>AI_LLAMA_STD_ExtraParams</code>       | <code>leer</code>     | Zusätzliche JSON-Parameter für Completion-Anfragen                              |

## 5.4 Externe KI (OpenAI-kompatibel)

| Property                                   | Standard           | Beschreibung                                            |
|--------------------------------------------|--------------------|---------------------------------------------------------|
| <code>AI_LLAMA_STD_ExternalUrl</code>      | <code>leer</code>  | API-URL (z. B. <code>https://api.openai.com/v1</code> ) |
| <code>AI_LLAMA_STD_ExternalApiKey</code>   | <code>leer</code>  | Bearer-API-Schlüssel                                    |
| <code>AI_LLAMA_STD_ExternalModel</code>    | <code>leer</code>  | Modellname (z. B. <code>gpt-4o</code> )                 |
| <code>AI_LLAMA_STD_ExternalNoPrompt</code> | <code>false</code> | System-Prompt überspringen                              |

## 5.5 Thinking- und Specialist-Modelle

| Property                                              | Beschreibung                             |
|-------------------------------------------------------|------------------------------------------|
| <code>AI_LLAMA_STD_ThinkingModelUrl</code>            | GGUF-URL für dediziertes Thinking-Modell |
| <code>AI_LLAMA_STD_SPECIALIST_&lt;Name&gt;</code>     | URL eines lokalen Specialist-Modells     |
| <code>AI_LLAMA_STD_EXT_SPECIALIST_&lt;Name&gt;</code> | URL einer externen Specialist-API        |

| Property                               | Beschreibung                          |
|----------------------------------------|---------------------------------------|
| AI_LLAMA_STD_EXT_SPECIALIST_Key_<Name> | API-Schlüssel für externen Specialist |

## 5.6 Whisper

| Property                      | Standard             | Beschreibung                     |
|-------------------------------|----------------------|----------------------------------|
| AI_Whisper_Port               | 8393                 | Lokaler Port des Whisper-Servers |
| AI_Whisper_ModelUrl           | ggml-small (~466 MB) | GGML-Modell-URL                  |
| AI_Whisper_Release            | v1.7.6               | whisper.cpp Release-Tag          |
| AI_Whisper_NoGpu              | false                | GPU deaktivieren (CPU-only)      |
| AI_Whisper_AutoDetectLanguage | false                | Automatische Sprachendetektion   |
| AI_Whisper_ExternalUrl        | leer                 | Externe STT-API-URL              |
| AI_Whisper_ExternalApiKey     | leer                 | API-Schlüssel für externe STT    |

## 5.7 Tesseract

| Property                     | Standard      | Beschreibung                                        |
|------------------------------|---------------|-----------------------------------------------------|
| AI_Tesseract_Languages       | deu           | Sprachen für OCR ( + -getrennt)                     |
| AI_Tesseract_PoolSize        | auto          | Anzahl paralleler Tesseract-Instanzen               |
| AI_Tesseract_MavenRepository | Maven Central | Alternativer Repository-Mirror für JNI-Bibliotheken |

## 5.8 AI-Proxy

| Property            | Beschreibung                                      |
|---------------------|---------------------------------------------------|
| AI_Proxy_AllowedIPs | Komma-getrennte IPs/CIDRs (leer = alle blockiert) |
| AI_Proxy_Users      | Komma-getrennte benutzer:passwort -Paare          |

## 5.9 Allgemein

| Property                                      | Standard                                 | Beschreibung                                   |
|-----------------------------------------------|------------------------------------------|------------------------------------------------|
| <code>AI_CachedImageExpiration</code>         | <code>600000</code> ms                   | TTL des Bild-Caches (Standard: 10 Minuten)     |
| <code>AI_QueueBadge</code>                    | <code>false</code>                       | Warteschlangen-Position in der UI anzeigen     |
| <code>AI_LLAMA_STD_FallbackLocation</code>    | <code>leer</code>                        | Fallback-Standort bei Geolokalisierungsfehlern |
| <code>AI_LLAMA_STD_NominatimDomain</code>     | <code>nominatim.openstreetmap.org</code> | Domain für Reverse-Geocoding                   |
| <code>AI_LLAMA_STD_IpGeolocationDomain</code> | <code>ipwho.is</code>                    | Domain für IP-Geolokalisierung                 |

## 6. Netzwerkfreigaben

Die folgenden Domains sind für den **Erststart** (einmaliger Download) erforderlich. Nach dem Download laufen alle KI-Dienste vollständig lokal.

| Domain                                     | Zweck                               | Optional             |
|--------------------------------------------|-------------------------------------|----------------------|
| <code>github.com</code>                    | llama.cpp- und whisper.cpp-Releases | Nein*                |
| <code>objects.githubusercontent.com</code> | GitHub Release-Asset-CDN            | Nein*                |
| <code>api.github.com</code>                | Update-Check (Release-Check)        | Ja                   |
| <code>huggingface.co</code>                | GGUF-Modell-Downloads               | Nein*                |
| <code>repo1.maven.org</code>               | Tesseract JNI-Bibliotheken (tess4j) | Ja (Spiegel möglich) |
| <code>raw.githubusercontent.com</code>     | Tesseract traineddata               | Ja                   |

\* Entfällt bei vollständig konfiguriertem Offline-Deployment mit eigenen Modell-URLs.

**Laufzeit (nur bei aktivierten Opt-In-Diensten)**

| Domain                                   | Dienst              | Opt-In-Property                       |
|------------------------------------------|---------------------|---------------------------------------|
| <code>api.search.brave.com</code>        | Brave Websuche      | <code>AI_BraveSearch_ApiKey</code>    |
| <code>nominatim.openstreetmap.org</code> | Reverse-Geocoding   | aktiver Standortdienst                |
| <code>ipwho.is</code>                    | IP-Geolokalisierung | aktiver Standortdienst                |
| <i>konfigurierbar</i>                    | Externe KI-API      | <code>AI_LLAMA_STD_ExternalUrl</code> |
| <i>konfigurierbar</i>                    | Externe Whisper-API | <code>AI_Whisper_ExternalUrl</code>   |

## 7. Datenschutz (DSGVO)

### 7.1 Datenverarbeitung im Standardbetrieb (lokal)

Im Standardbetrieb mit lokalen Modellen verlassen **keine Nutzerdaten** den formcycle-Server.

| Verarbeitungsschritt                               | Speicherort                 | Persistenz                                               |
|----------------------------------------------------|-----------------------------|----------------------------------------------------------|
| Chat-Nachrichten / Dokumenteninhalte               | RAM (Prozesskontext)        | Nicht persistent                                         |
| Bilder / PDFs                                      | RAM + temporärer Dateicache | TTL: 600 s (konfigurierbar), danach automatisch gelöscht |
| Audio (Whisper)                                    | RAM (Prozesskontext)        | Nicht persistent                                         |
| OCR-Ergebnisse (Tesseract)                         | RAM                         | Nicht persistent                                         |
| Proxy-Audit-Log<br>( <code>codbi_ai_proxy</code> ) | Datenbank (JPA)             | Persistent (nur Metadaten, s. u.)                        |

### 7.2 Audit-Tabelle `codbi_ai_proxy`

Die Audit-Tabelle protokolliert **ausschließlich technische Metadaten** — kein personenbezogener Inhalt wird gespeichert:

| Spalte                  | Inhalt                       | Datenschutzrelevanz             |
|-------------------------|------------------------------|---------------------------------|
| <code>request_id</code> | UUID (zufällig generiert)    | Keine Rückverfolgung auf Person |
| <code>timestamp</code>  | Zeitstempel der Anfrage      | Gering (keine Nutzerzuordnung)  |
| <code>endpoint</code>   | Aufgerufener API-Endpunkt    | Keine personenbezogenen Daten   |
| <code>status</code>     | HTTP-Statuscode              | Keine personenbezogenen Daten   |
| <code>elapsed_ms</code> | Antwortzeit in Millisekunden | Keine personenbezogenen Daten   |

Klarnamen, IP-Adressen und Anfrageinhalte werden bewusst

**NICHT**

protokolliert. Benutzernamen werden im internen Logging nur als SHA-256-Hash geführt.

## 7.3 Verantwortlichkeit und Rechtsgrundlagen

| Szenario                             | Empfehlung                                                                                                               |
|--------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| <b>Lokaler Betrieb</b><br>(Standard) | Verarbeitung auf dem eigenen Server; DSFA prüfen, ob Nutzendendaten (z. B. Formulareingaben) sensibel sind               |
| <b>Externe KI-API</b>                | Daten verlassen den Server → <b>AVV mit Anbieter</b> zwingend erforderlich; Drittlandtransfer prüfen (Art. 44 ff. DSGVO) |
| <b>Brave Search</b>                  | Suchanfragen verlassen den Server → AVV mit Brave prüfen; Datenschutzhinweis an Nutzende                                 |
| <b>Externe Whisper-API</b>           | Audiodaten verlassen den Server → <b>AVV</b> erforderlich                                                                |
| <b>Browser Web Speech API</b>        | Cloud-Dienst des Browsers (Google/Microsoft) → <b>Einwilligung der Nutzenden</b> erforderlich                            |

## 7.4 Betroffenenrechte

Im Standardbetrieb (lokale Modelle, kein persistenter Inhalt) sind typische Betroffenenrechte (Auskunft, Löschung, Berichtigung) technisch im Wesentlichen gegenstandslos, da keine inhaltlichen

personenbezogenen Daten dauerhaft gespeichert werden. Bei aktivierten Opt-In-Diensten oder externer Verarbeitung gelten die üblichen DSGVO-Anforderungen.

## 8. EU-KI-Verordnung (AI Act)

CodBi enthält Maßnahmen zur Erfüllung der **Transparenzpflichten nach Art. 50 EU AI Act**.

### 8.1 Kennzeichnungspflicht (Art. 50 Abs. 1)

KI-generierte Inhalte werden in der formcycle-Benutzeroberfläche automatisch mit dem Label ✨ **KI-generiert** gekennzeichnet. Dies gilt für alle Ausgaben der Komponenten `AI.Llama.Standard.QA` und `AI.Llama.Standard.TxtQA`.

### 8.2 Transparenz im System-Prompt

Der Standard-System-Prompt injiziert automatisch:

- Aktuelles Datum, Uhrzeit und Wochentag (Präzision ohne Cloud)
- Einen **EU-AI-Act-Transparenzhinweis** als Kontextinformation für das Modell

### 8.3 Risikoklassifizierung

| Aspekt                          | Einschätzung                                       | Handlungsbedarf                                                     |
|---------------------------------|----------------------------------------------------|---------------------------------------------------------------------|
| Risikostufe                     | Abhängig vom Einsatzszenario                       | Betreiber muss Risikoklasse für den konkreten Anwendungsfall prüfen |
| Transparenz gegenüber Nutzenden | ✨ KI-generiert-Label implementiert                 | Ausreichend für niedrige Risikostufe                                |
| Menschliche Kontrolle           | Nutzer kann KI-Vorschläge ablehnen                 | Prozess dokumentieren                                               |
| Protokollierung                 | Audit-Log in <code>codbi_ai_proxy</code> vorhanden | Ggf. erweitern für hochriskante Anwendungen                         |
| Dokumentation                   | Modellherkunft und -eigenschaften dokumentieren    | Systemdokumentation für regulierte Bereiche                         |

## 8.4 MailBridge und Transparenz

E-Mails, die über die MailBridge versendet werden, erhalten einen konfigurierbaren **Pflicht-Disclaimer** (Standard: `AI-Generated`). Dies erfüllt die Kennzeichnungspflicht für KI-generierte Kommunikation.

## 9. Sicherheitsarchitektur

### 9.1 Netzwerksicherheit

- **Ausschließlich localhost-Kommunikation:** LLaMA- und Whisper-Server binden nur an `127.0.0.1` — sie sind von außen nicht erreichbar
- **AI-Proxy als einziger Zugangspunkt:** Externer Zugriff erfolgt ausschließlich über den authentifizierten Proxy-Endpunkt
- **IP-Whitelist (CIDR + Exact):** Zugriff auf den Proxy auf IP-Ebene einschränkbar
- **HTTP Basic Auth:** Zusätzliche Authentifizierungsschicht

### 9.2 SSRF-Schutz (UrlFetcher)

Der `UrlFetcher`-Dienst enthält expliziten Schutz gegen Server-Side Request Forgery (SSRF): private IP-Bereiche ( `10.x.x.x` , `192.168.x.x` , `172.16-31.x.x` ) und `localhost` sind blockiert. Nur externe, öffentliche URLs werden zugelassen.

### 9.3 Download-Sicherheit (Zip-Slip-Schutz)

Der `DownloadManager` enthält expliziten Schutz gegen **Zip-Slip-Angriffe** bei der Extraktion von ZIP- und tar.gz-Archiven (llama.cpp- und whisper.cpp-Releases).

### 9.4 Ressourcenschutz

- **Semaphore (FIFO):** Maximale Anzahl paralleler KI-Anfragen begrenzt ( `AI_LLAMA_ENGINE_MaxConcurrent` )
- **RAM/CPU-Guards:** Anfragen werden abgelehnt, wenn die Systemauslastung konfigurierte Schwellwerte überschreitet
- **Streaming-Session-TTL:** Sessions laufen nach 5 Minuten (Standard) bzw. 10 Minuten (Thinking) automatisch ab

### 9.5 MailBridge-Sicherheit

- Empfänger werden gegen eine **Regex-Whitelist** geprüft — unkonfiguriert ist kein Versand möglich
- Rate-Limiting auf globaler und Sitzungsebene verhindert Missbrauch

## 10. Externe KI-Dienste und Risikobewertung

| Dienst                                     | Aktivierung                    | Weitergeleitete Daten                              | DSGVO           | Maßnahme                                                  |
|--------------------------------------------|--------------------------------|----------------------------------------------------|-----------------|-----------------------------------------------------------|
| <b>Lokales LLaMA</b>                       | Standard                       | Keine (lokal)                                      | unkritisch      | —                                                         |
| <b>Lokaler Whisper</b>                     | Standard                       | Keine (lokal)                                      | unkritisch      | —                                                         |
| <b>Tesseract</b>                           | Standard                       | Keine (lokal, in-process)                          | unkritisch      | —                                                         |
| <b>Brave Search API</b>                    | AI_BraveSearch_ApiKey          | Suchanfragen                                       | Prüfen          | AVV mit Brave; Datenschutzhinweis                         |
| <b>Nominatim (OSM)</b>                     | Geolokalisierung aktiv         | Koordinaten                                        | Gering          | Datenschutzhinweis auf OSM-Nutzungsbedingung              |
| <b>ipwho.is</b>                            | Geolokalisierung aktiv         | Server-IP                                          | Gering          | Datenschutzhinweis eigene Domain konfigurierbar           |
| <b>Externe KI-API (z. B. GPT-4o, Groq)</b> | AI_LLAMA_STD_ExternalUrl       | <b>Gesamter Chat-Inhalt inkl. ggf. Bürgerdaten</b> | <b>Kritisch</b> | AVV zwingend; Drittlandtransfer prüfen; ggf. Einwilligung |
| <b>Externe Whisper-API</b>                 | AI_Whisper_ExternalUrl         | <b>Audiodaten</b>                                  | <b>Kritisch</b> | AVV zwingend; Drittlandtransfer prüfen                    |
| <b>HuggingFace</b>                         | Erster Start (Modell-Download) | Keine Nutzerdaten                                  | unkritisch      | Einmalig; Offline-Deployment möglich                      |

| Dienst                        | Aktivierung                    | Weitergeleitete Daten                 | DSGVO           | Maßnahme                                      |
|-------------------------------|--------------------------------|---------------------------------------|-----------------|-----------------------------------------------|
| <b>GitHub API</b>             | Erster Start + Update-Check    | Keine Nutzerdaten                     | unkritisch      | Deaktivierbar                                 |
| <b>Browser Web Speech API</b> | Browser-native Formulareingabe | <b>Audiodaten an Google/Microsoft</b> | <b>Kritisch</b> | Einwilligung der Nutzenden; unabhängig von Co |

## 11. Betrieb und Monitoring

### 11.1 Health-Monitoring

- **Health-Check-Polling** auf `/health`-Endpunkt der lokalen Server
- **ResourceMonitor** (Daemon-Thread): CPU- und RAM-Auslastung alle 3 Sekunden; GPU-Auslastung via `nvidia-smi` (CUDA)
- **Automatischer Neustart** bei Prozessabsturz

### 11.2 Logging

| Ebene                                        | Inhalt                                           | Hinweis                                 |
|----------------------------------------------|--------------------------------------------------|-----------------------------------------|
| Plugin-Log (formcycle)                       | Start/Stop-Ereignisse, Fehler, Health-Status     | Standard-formcycle-Logging              |
| Audit-Tabelle<br><code>codbi_ai_proxy</code> | Anfrage-Metadaten (UUID, Endpunkt, Status, Zeit) | Datenschutzkonform (keine Inhaltsdaten) |
| Benutzername-Hashing                         | SHA-256 im internen Log                          | Kein Klartext-Benutzername              |

### 11.3 Ressourcenplanung

| Ressource | Minimum | Empfohlen (GPU) |
|-----------|---------|-----------------|
| RAM       | 8 GB    | 16 GB+          |

| Ressource            | Minimum                     | Empfohlen (GPU)                       |
|----------------------|-----------------------------|---------------------------------------|
| CPU                  | 4 Kerne                     | 8+ Kerne                              |
| GPU (optional)       | VRAM 4 GB                   | VRAM 8 GB+ (CUDA/Vulkan)              |
| Festplatte           | 5 GB (Modelle)              | 10 GB+ (mehrere Modelle)              |
| Netzwerk (Erststart) | Einmaliger Download ~2,4 GB | Schnelle Internetverbindung empfohlen |

## 11.4 Wartung

- **Modell-Updates:** Neue GGUF-Modelle können jederzeit durch Anpassen der `*_ModelUrl`-Properties eingespielt werden (formcycle-Neustart erforderlich)
- **Binary-Updates:** `AI_LLAMA_ENGINE_Release` und `AI_Whisper_Release` auf neue Release-Tags setzen
- **Offline-Deployment:** Alle URLs können auf interne Spiegel oder Dateipfade umgeleitet werden

## 12. Checkliste für den produktiven Betrieb

### VOR DER ERSTINSTALLATION

- ☐ Systemanforderungen (RAM, CPU/GPU) geprüft
- ☐ Netzwerkfreigaben für Erstdownload beantragt (github.com, huggingface.co)
- ☐ Datenschutz-Folgenabschätzung (DSFA) für den geplanten Anwendungsfall durchgeführt
- ☐ Zuständigen Datenschutzbeauftragten informiert

### KONFIGURATION

- ☐ `Active_AI` auf benötigte Komponenten gesetzt
- ☐ `AI_Proxy_AllowedIPs` konfiguriert (Whitelist nicht leer lassen)
- ☐ `AI_Proxy_Users` mit sicheren Passwörtern gesetzt
- ☐ `AI_LLAMA_ENGINE_MaxConcurrent` auf Serverlast abgestimmt

☐ Ggf. `AI_LLAMA_STD_Language` für einsprachigen Betrieb gesetzt

☐ `AI_Tesseract_Languages` auf benötigte Sprachen gesetzt

## EXTERNE DIENSTE (NUR BEI AKTIVIERUNG)

☐ **Externe KI-API:** AVV mit Anbieter abgeschlossen; Datenschutzhinweis für Nutzende

☐ **Brave Search:** API-Schlüssel sicher gespeichert; AVV geprüft

☐ **MailBridge:** `AI_Mail_AllowedRecipients` konfiguriert; Disclaimer angepasst

☐ **Browser Web Speech API:** DSGVO-Einwilligung der Nutzenden sichergestellt

## COMPLIANCE

☐ EU AI Act Risikoklasse für den Anwendungsfall bestimmt

☐ ✨ KI-generiert-Kennzeichnung in der UI überprüft

☐ Audit-Log ( `codbi_ai_proxy` ) in Datenschutzdokumentation aufgenommen

☐ Lösch-/Aufbewahrungskonzept für `codbi_ai_proxy` -Tabelle definiert

☐ Verzeichnisse (Art. 30 DSGVO) aktualisiert

## BETRIEB

☐ Health-Monitoring eingerichtet

☐ Ressourcenmonitoring (CPU/RAM) konfiguriert

☐ Backup-Strategie für Modell-Downloads (offline-fähig)

☐ Update-Prozess für Modelle und Binaries definiert

Dieses Dokument bezieht sich auf CodBi ab Version 1.0.1 (Stand: April 2026). | Für Fragen wenden Sie sich an die Projektverantwortlichen unter [Salvatore.Callari@Ansbach.de](mailto:Salvatore.Callari@Ansbach.de).